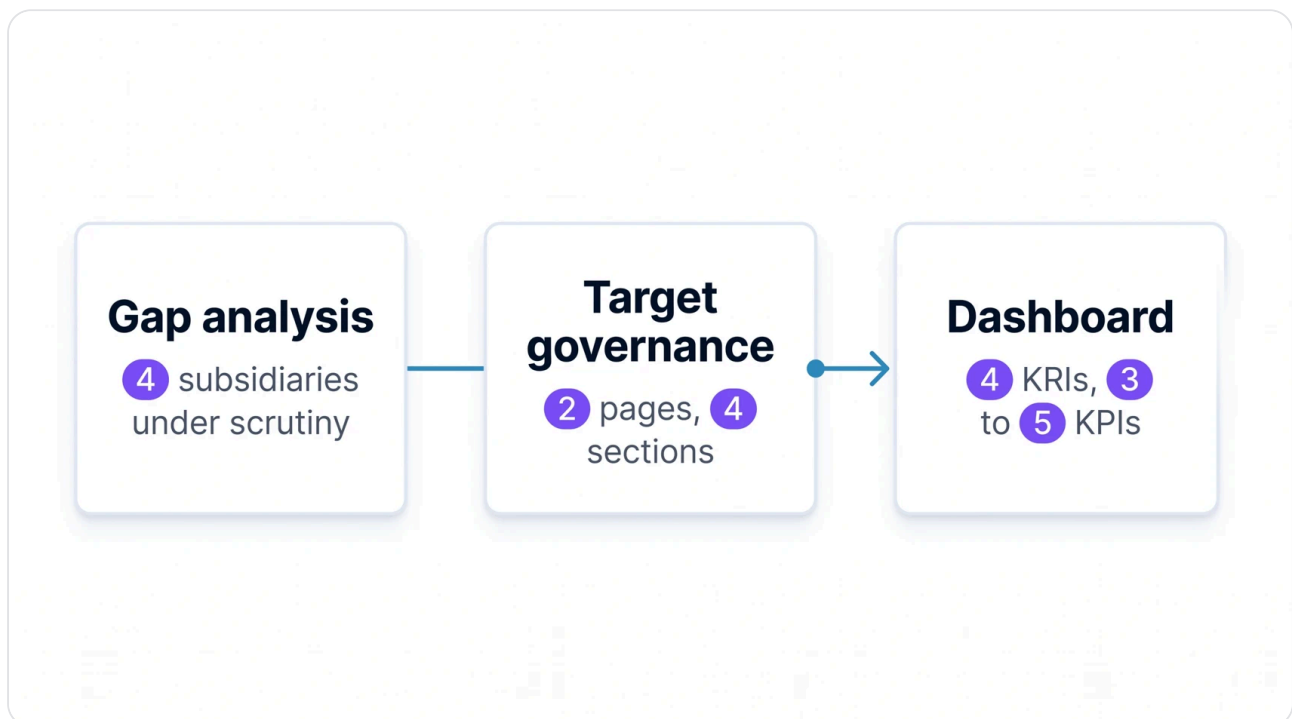


Framing the MERIDIAN case and target governance

Objective: by the end of the hour, the group's governance exists on paper

Session objectives

By the end of this lab, the MERIDIAN dossier contains three documents: the group's gap analysis, four subsidiaries sifted through the morning's principles; the written target governance, bodies, RACI matrix, codified directives and arbitration rules; and the Group CISO's first indicator dashboard. What is learned here:



The three documents produced within the hour, in the order they follow one another.

- **Conduct** a gap analysis: comparing an existing state to a target and drawing defensible priorities from it
- **Draft** a governance charter in which every rule is applicable, dated and carried by an owner
- **Distinguish** a KPI from a KRI, and build indicators that trigger decisions rather than slides

Prerequisites

- The morning lecture: the bodies, the corrected RACI grid, the codification of risk appetite. Copying them into a binding document is a different exercise from understanding them.
- The tutorial: the three principles and the findings per subsidiary, which here become the raw material of the gap analysis.

- The CISO's briefing: Monday's three files, whose reappearance the target governance must prevent.

Three tooling notions before writing

Gap analysis, first, because it is the founding move of this entire module and it will be redone in every session in different forms. The problem it addresses: faced with an imperfect existing state, intuition lists defects in bulk, and management receives an unusable inventory of reproaches. Gap analysis is the methodical comparison between an observed state and an explicit target, producing for each gap: the finding, the rule or principle violated, and the priority. Its mechanics carry a hidden requirement: the TARGET must exist before the analysis; without a written target, one does not measure gaps, one voices opinions. Its limit: it photographs, it does not correct; an analyzed gap is not a treated gap, and the temptation to confuse the two is eternal.

The governance charter, next. The problem: the morning's decisions, bodies, RACI, arbitrations, exist legally nowhere as long as they live in slides. The governance charter is the short document that sets down, in black and white and signed at the right level, who decides what in security matters: the bodies and their prerogatives, the RACI matrix of key processes, the arbitration rules, and the directives the group imposes on its subsidiaries. Its writing mechanics, which this lab puts into practice: each rule is phrased to be VERIFIABLE, with an owner and, when needed, a deadline. Its limit, already met in the lecture: a charter has only the authority of those who sign it; that is why the RACI places the Executive Committee as approver of the PSSI, not the CISO.

KPI and KRI indicators, finally, the duo every executive briefing confuses. The module's working definition rests on one opposition: a **KPI**, key performance indicator, measures the EFFECTIVENESS of a security measure, it looks at what is being done; a **KRI**, key risk indicator, ALERTS on EXPOSURE, it looks at what threatens the organization. "Share of privileged accounts protected by MFA" is a KPI: it measures the progress of a measure. "Share of obsolete operating systems" is a KRI: it measures an exposure that grows on its own if nobody acts. The mechanics that make an indicator useful: a TARGET and an alert THRESHOLD, both decided in advance, because a figure without a threshold is information, not a steering instrument. The genre's limit: too many indicators kill the indicator; an executive dashboard that exceeds ten lines will never be read, it will be skimmed.

For every rule and every indicator written in this lab, the skeptic's question is required: "how would one know it is NOT being complied with?". If the answer is not obvious, the phrasing is not verifiable, and an unverifiable rule is a wish with a number.

Exercise 1: the group's gap analysis (20 minutes)

The target has existed since this morning: the tutorial's structuring principles and the lecture's governance architecture. So does the existing state: the findings accumulated on the four subsidiaries throughout the day, to which are added two reports just received by the Group CISO: the Santé subsidiary reports local passwords without multi-factor authentication on business applications; the Territoires subsidiary confirms that its event logs are kept locally, on each system, without centralization.

1. **Build** the group's gap analysis table on this model, covering the four subsidiaries from all the day's findings:

SUBSIDIARY	OBSERVED GAP	TARGET PRINCIPLE OR RULE VIOLATED	PRIORITY (1 TO 3) AND ONE-LINE JUSTIFICATION
...	...	...	...

1. **Prioritize** without egalitarianism: at most two gaps at priority 1 for the entire group, and the justification of each priority must invoke the subsidiary's MISSION, not technical severity alone (hint: a medium gap on a vital system can come before a serious gap on a secondary system).

2. **Spot** the gap that belongs to no subsidiary: which of the day's findings is a GOVERNANCE gap of the group itself? Add it to the table on a "Group" row.

Exercise 2: drafting the target governance (25 minutes)

This is the centerpiece. The document, two pages at most, is titled "Target governance of MERIDIAN group security" and comprises four sections.

1. **Carry over** in section 1 the bodies and the distribution of roles over risk appetite, and in section 2 the RACI grid of key processes, as the lecture established them; copying them is allowed, but each table must be followed by a sentence stating what it prevents (Monday's three files are the yardstick: the governance must make each one impossible, and say so).

2. **Draft** in section 3 the group's codified directives: at least five directives, under the codification [PSSI-CADRE-XXX-nn], mandatorily covering these five themes: authentication of remote access and administration privileges; review of privileges on business databases; notification of major incidents to the Group CISO; log collection; handling of critical patches. Each directive passes the skeptic's test: verifiable, identifiable owner, deadline or frequency when the nature of the theme requires it.

3. **Draft** in section 4 the inter-subsidiary arbitration rules, as three rules: the Group CISO's power in the face of a disagreement between subsidiaries (hint: the lecture showed an arbitration that suspends without burying); the emergency power of a subsidiary CISO over an inter-subsidiary flow in the event of a confirmed compromise; and the derogation circuit for the framework PSSI, with its validation deadline.

Exercise 3: the Group CISO's first dashboard (15 minutes)

1. **Build** the executive dashboard: at most four KRIs, each with its target and alert threshold, covering four different group exposures. Beware of the genre's trap: an exposure grows on its own if nobody acts, whereas a program being rolled out is measured with a KPI. One hint per exposure: what the SOC does not see, the aging of the fleet, the accounts that designate nobody, and the human factor.

2. **Define** three to five implementation KPIs, attached to the directives of exercise 2: each KPI measures the progress of ONE specific directive, with its target value.

3. **Verify** the overall consistency: every priority 1 of the gap analysis must be watched by at least one indicator in the dashboard. If not, one of the two documents is lying.

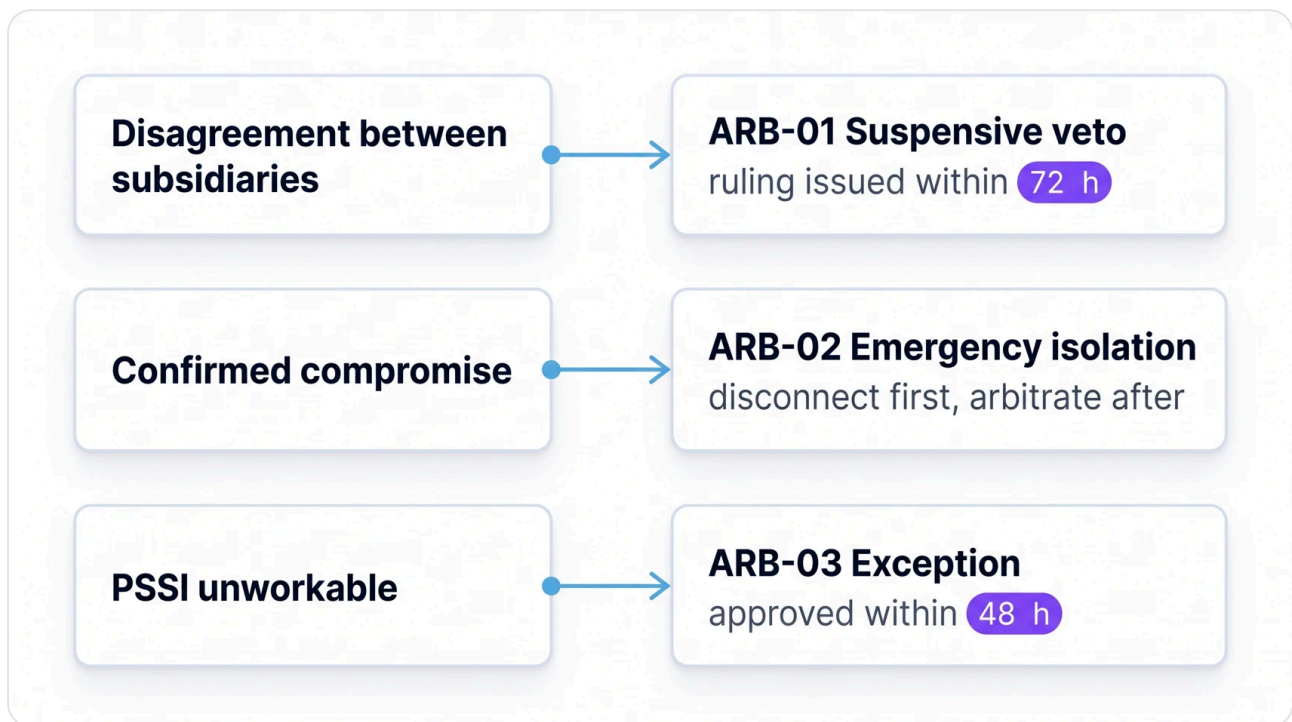
Answer keys and assessment criteria

Answer key for exercise 1: the expected gap table

The day's gaps, attached and prioritized (the wording may differ, the structure may not): Santé, laboratory analyzers and imaging consoles on the office IP range with a common administrator account, violation of isolation and least privilege, priority 1, because the care mission rests on it; Santé again, local passwords without multi-factor authentication on business applications, priority 2. Logistique, interconnected IT/OT networks and a domain account shared with the Third-Party Maintenance Provider, violation of isolation and least privilege, priority 1, the group's shipping continuity depends on it. Éducation, shared administrator accounts, least privilege, priority 2, aggravated by the subsidiary's limited resources. Territoires, logs kept locally without centralization, priority 2, because without centralized logs, neither detection nor post-incident analysis, and a clientele of local authorities that will demand accounts. And the "Group" row, the one the exercise asked to see: the absence of a framework PSSI and of arbitration rules IS the governance gap from which all the others flow; it is the one exercise 2 addresses, and it could only sit on the Group row, since no subsidiary can close it alone.

Answer key for exercise 2: the reference target governance

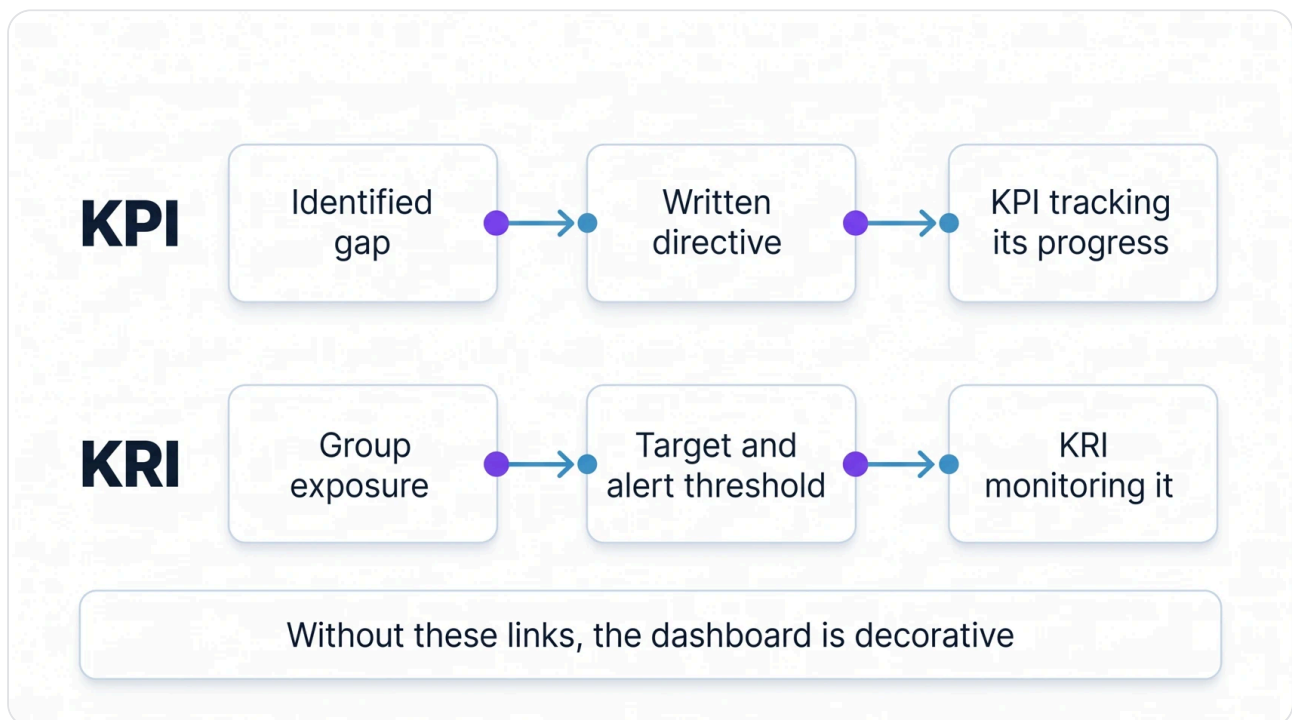
The group's directives, as the MERIDIAN dossier now codifies them, to be compared afterwards against a single criterion, the skeptic's test. [PSSI-CADRE-ACC-01] Multi-factor authentication required for all remote access and all administration privileges. [PSSI-CADRE-ACC-02] Quarterly review of access privileges on business databases. [PSSI-CADRE-INC-01] Notification of any major incident to the Group CISO within 2 hours. [PSSI-CADRE-JRN-01] Log collection toward the group's centralized SOC, currently ramping up. [PSSI-CADRE-COR-01] Every critical patch applied within 14 days. The five codes cover exactly the five imposed themes, one prefix per theme: ACC for access, INC for incidents, JRN for logs, COR for patches. A codification that leaves a theme without a code, or codes a rule outside the themes, is not a codification. The arbitration rules: [ARB-01] the Group CISO holds a suspensive veto over any subsidiary decision committing the group's security, with an arbitration rendered within 72 hours, a veto that suspends without burying, which is what makes it acceptable; [ARB-02] every subsidiary CISO holds an emergency isolation right over any inter-subsidiary flow in the event of a confirmed compromise, because in a crisis one cuts first and arbitrates afterwards; [ARB-03] any derogation from the framework PSSI is validated by the Group CISO within 48 hours, because a derogation without a circuit becomes an acquired right. Finally, the priority directives per subsidiary, which translate the gap analysis: Santé, AES-256 encryption of data at rest; Logistique, strict IT/OT segmentation; Éducation, generalized multi-factor authentication; Territoires, centralized logging toward the SOC.



The three arbitration circuits, each with its deadline.

Answer key for exercise 3: the reference dashboard

The group's four executive KRIs, each measuring an exposure that grows on its own if nobody acts: share of the perimeter not monitored, that is, logs not collected toward the SOC, target below 5 %, threshold beyond 20 %; share of obsolete operating systems, target below 5 %, threshold beyond 15 %; non-nominative privileged accounts, target zero, threshold beyond five; click rate in phishing campaigns, target below 5 %, threshold beyond 15 %. Three indicators many classify as KRIs are not, and that is the error this answer key expects: PSSI coverage, mean time to detect, and the awareness rate measure the progress of a program, hence the effectiveness of what is being done. They are steering KPIs. They have their place on the dashboard, under the right heading, and they do not count among the three to five KPIs attached to the directives. The implementation KPIs attached to the directives: privileged accounts protected by MFA, target 100 %; inactive accounts not revoked within 30 days, target zero; critical vulnerabilities not patched at 14 days, target zero; mean notification time for major incidents, target below 30 minutes, the directive remaining enforceable at 2 hours: the internal target is stricter than the obligation, that is the point of a target; critical gaps unresolved at 30 days, target zero. The grammar of the whole: each KRI watches an exposure, each KPI measures a directive, and the two priority 1s of the gap analysis are each covered by a named indicator: Santé's common administrator account by the KRI of non-nominative privileged accounts, doubled by the MFA coverage KPI; Logistique's network interconnection by the KRI of the unmonitored perimeter, doubled by the KPI of unresolved critical gaps, since that is how the progress of the segmentation directive is measured. A dashboard that does not show these attachments is decorative.



The attachment that makes a dashboard steerable.

Assessment criteria

CRITERION	INSUFFICIENT	EXPECTED	EXCELLENT
Gap analysis	List of defects without target or priority	Complete table, priorities justified by the mission	The "Group" row identified: the absence of a framework as the root gap
Directives	Unverifiable wishes ("strengthen security")	Five themes covered, codified, verifiable	Each directive passes the skeptic's test, deadlines and owners included
Arbitration rules	Powers absolute or absent	Suspensive veto, emergency, derogation: the three circuits written	Same, with the justification of each balance (suspend without burying, cut then arbitrate)
Indicators	KPIs and KRIs confused, no thresholds	Four KRIs with target and threshold, KPIs attached to the directives	Same, with consistency closed against the gap analysis priority 1s
Monday's three files	Ignored	The target governance states what it prevents	Each of Monday's files linked to the rule that makes it impossible